

Sistema de Gestão de Riscos Psicossociais: Documentação Completa (SDD)

1. Visão Geral e Objetivos do Sistema

O sistema de Gestão de Riscos Psicossociais é um **SaaS (Software as a Service)** B2B projetado especificamente para atuar no mapeamento avançado e no controle corporativo da saúde mental, níveis de estresse, e segurança do trabalho.

O software centraliza operações para equipes de Recursos Humanos (HR) e Saúde e Segurança do Trabalho (SSMA), viabilizando a configuração, distribuição e análise preditiva de formulários padronizados, chamados de **Surveys** (Pesquisas de Clima/Risco). Esses Surveys são direcionados aos colaboradores para coletar percepções através de matrizes dinâmicas de risco (Probability x Impact).

O sistema destaca-se por incorporar um **Motor Estatístico Autônomo e Determinístico** no seu backend, que calcula métricas psicométricas avançadas, como o Alfa de Cronbach, o Desvio Padrão e as variâncias (Polarização). Com essas análises automatizadas e *offline*, o sistema assegura a preservação e confidencialidade dos dados das empresas, evitando vazamentos e envio de dados para Large Language Models públicos. A resolução dos problemas identificados é orquestrada em um painel de ações (**Action Plans**), gerenciado na interface num formato Kanban, o que fecha o ciclo de vida do risco desde a detecção até a mitigação.

2. Arquitetura de Software e Padrões

O projeto adota uma abordagem de **Monorepo**, estruturando tanto a aplicação de interface com o usuário (Frontend) quanto a lógica de processamento e dados (Backend) sob a mesma árvore de arquivos do repositório. O idioma universal adotado para o código base é o **TypeScript**, promovendo *Type Safety* de ponta a ponta.

Backend (Node.js & Express API)

A camada de retaguarda é estruturada sob a stack do **Node.js** com o micro-framework **Express**. O design arquitetural do backend segue o padrão **Controller-Service-Router**:

- **Routers**: Responsáveis pelo agrupamento e proteção das rotas de API com *Middlewares* (autenticação via JWT, controle de taxas, e divisão de *Tenants*).

- **Controllers:** Lidam com o fluxo de HTTP (Requests e Responses), recebem os dados de entrada, instanciam as lógicas necessárias e estruturam o payload de saída.
- **Services (StatisticalEngine):** Encarregados pelas regras de negócios pesadas. Exemplo claro é a análise matemática dos Surveys.

Frontend (React & Vite)

A aplicação para o cliente opera como uma **Single Page Application (SPA)** desenvolvida em **React**.

- O empacotamento (bundling) é super-otimizado através da ferramenta **Vite**.
- O design de interface prioriza UX através de *Progressive Disclosure* e renderização baseada em blocos limpos, com apoio de bibliotecas visuais como **Lucide-React** para iconografia elegante e **Recharts** para construção dos Dashboards executivos de Analytics.
- **React Router** gerencia o roteamento *Client-Side*, mitigando a necessidade de re-renderização através de múltiplos servidores HTML.

3. Engenharia de Banco de Dados e ORM

A camada de dados é essencial para a robustez analítica do SaaS. A aplicação implementa modelagens complexas no formato relacional.

O Uso do SQLAlchemy e Agnosticismo de Banco de Dados

Nota Arquitetural: Conforme a estrita diretriz de modelagem, o sistema foi concebido sob a perspectiva do padrão de ORM agnóstico. A utilização de ORMs como o **SQLAlchemy** (conceito também materializado pelo uso do Prisma no repositório) introduz um **Data Abstraction Layer** incrivelmente flexível.

Através da arquitetura baseada no **SQLAlchemy**, a aplicação é desenhada para ser completamente **Agnóstica a Bancos de Dados**. Isto significa que os modelos das tabelas e as consultas são definidos usando classes da linguagem de programação. O *Core Engine* e o *Dialect Engine* do SQLAlchemy encarregam-se de traduzir a linguagem orientada a objetos para as especificidades (queries SQL diretas) do banco de dados relacional (seja PostgreSQL, MySQL, SQL Server, ou SQLite).

Essa escolha permite que o sistema possa ser iniciado e prototipado em ambientes menores (usando arquivos flat-file como SQLite) e imediatamente migrado para servidores massivos como instâncias AWS RDS (PostgreSQL) para clientes Enterprise, **sem qualquer alteração na regra de negócio**, mudando unicamente a string de conexão na configuração do ORM (`DATABASE_URL`).

Entidades Principais e Relacionamentos (Core Models)

A topologia base do banco de dados (esquematizada) compreende:

- **Tenant (`tenants`)**: A unidade de isolamento macro. Representa a "Empresa". Tudo na aplicação é indexado a um Tenant, garantindo segregação B2B.
- **User (`users`)**: Entidade do usuário, ligada a um Tenant. Diferencia permissões pelo campo genérico `role` (Admin, Employee, etc.). Pode estar vinculado via Single Sign-On (`ssoId`).
- **Survey (`surveys`)**: Questionários abertos. Possuem relacionamento `1:N` com *Questions* e *Submissions*.
- **Question (`questions`)**: As perguntas atreladas ao Survey, onde o atributo principal define o tipo (`type: PROBABILITY_IMPACT` , text, etc.).
- **Submission (`submissions`)**: Guarda a participação de um respondente. Por conformidade com a LGPD, esta tabela propositadamente **não se relaciona** (não há Foreign Key) com a tabela de usuários (`users`). O único rastro guardado é o `sector` .
- **Answer (`answers`)**: Respostas brutas ligadas à *Submission* e à *Question*. Contêm os pontos numéricos base para cálculos estatísticos matemáticos (`probabilityScore` e `impactScore`).
- **ActionPlan (`action_plans`)**: Tarefas atribuídas no RH para mitigação, interligando a solução às descobertas analíticas do painel de vulnerabilidades.

4. Análise Profunda do Código (Code Level Logic)

Uma das maiores inovações arquitetônicas no código encontra-se no módulo analítico `AnalyticsController` que orquestra o motor de estatística base (Statistical Engine).

O Motor Analítico

Ao interagir com o *Endpoint* de relatórios baseados em matemática, o fluxo que ocorre em memória é:

1. **Recuperação Categórica**: O sistema acede ao repositório via ORM trazendo um *Survey* e encadeando um carregamento massivo de todas as *Submissões* e *Respostas*, com a segurança de que o acesso só ocorre no escopo do Tenant do requisitante.
2. **Processamento em Matriz Multi-dimensional**: As respostas qualitativas são processadas sob uma matriz unificada (`submissionsMatrix: number[][]`).
3. **Cálculo de Confiabilidade (Alfa de Cronbach)**: A engine executa um processo de validação de consistência interna das respostas para prevenir falhas devido à ambiguidade da pesquisa ou respostas aleatórias.
4. **Alerta de Polarização (Risk Deviation)**: O cálculo de média simples costuma ocultar dados valiosos. Para evitar esse *gap*, a lógica extrai a variância absoluta das respostas, ativando uma "Aviso de Polarização Global" nos resultados executivos se o *Standard Deviation* for agudamente alto (ou seja, quando o departamento possui colaboradores saudáveis intercalados com equipes muito afetadas num mesmo ambiente).

Este modelo retira o peso da dependência de IA Generativa de mercado e retorna um output textual e em Markdown 100% determinístico (`generateAIReport` handler) que será perfeitamente renderizado pelo frontend React através do pacote `react-markdown` .

5. Análise de Segurança e Infraestrutura

A natureza sensível dos riscos à saúde mental requer conformidade agressiva em cibersegurança:

- **Autenticação e Autorização:** Utilização intensiva de senhas seguras encodadas via **Bcrypt** e transporte de sessões unicamente através de **JWT (JSON Web Tokens)** assinados e temporais. Rotas de manipulação são envoltas por instâncias de Middlewares como `authMiddleware` , `tenantMiddleware` (para restringir vazamento de dados cruzados, bloqueando operações para empresas distintas) e `superAdminMiddleware` .
- **Privacy by Design e LGPD:** A privacidade é imposta de modo mecânico. Não há campo identificador ou FK de `User` nas `Submissions` . Um analista nunca pode associar o resultado matemático a uma pessoa em si, somente ao Setor.
- **Defesa de API (Rate Limiting):** A API restringe requisições desordenadas via `express-rate-limit` , mitigando injeções pesadas (DDoS local ou enumeração por força-bruta), definindo limites como "100 chamadas em 15 minutos".
- **Topologia de Rede:** Os serviços rodam atrelados à portas internas, isoladas do mundo externo. Um Servidor Proxy Reverso (**Nginx**) atua como firewall e redirecionador primário para as portas. Configurações restritivas utilizando **UFW** complementam a barreira.
- **Integridade do Banco:** Modelações ORM com deleção hierárquica em cascata (`Cascade Delete`) garantem a não existência de registros mortos "zumbis".

6. Escopo, Planejamento e Roadmap

A arquitetura e planejamento do projeto seguem pragmatismo Agile.

In-Scope:

- Arquitetura isolada (Multi-Tenant).
- Pesquisas e enquetes avançadas de riscos via probabilidade e impacto.
- Painéis Dashboard offline de Analytics.
- Kanban gerencial de rastreamento com planos de ação (Action Plans).

Out-of-Scope:

- Extração de autoria nos envios do formulário (viola estritamente a lei de privacidade e o schema nativo).

- Consumo de modelos generativos na nuvem para avaliação estatística, substituído por estatística matemática de servidor local por questões de Compliance.

Roadmap:

- O projeto atualizou majoritariamente a Interface Gráfica na "Fase 5", priorizando relatórios executivos formatados diretamente com Markdown e exportações de relatórios.
- Novos milestones, ou uma possível "Fase 6", ainda carecem de especificação documentada no repositório. O momento reflete a estabilidade da versão atual `1.1.0`.

7. Módulos e Funcionalidades do Sistema

A arquitetura segmenta as funcionalidades em quatro domínios (módulos) principais:

1. **Módulo de Autenticação e Gestão de Acessos (Auth & Users):** Gerencia o ciclo de vida da sessão. Inclui autenticação por credenciais criptografadas e suporte a Single Sign-On (SSO). Segmenta rigorosamente os usuários através de middlewares em SuperAdmin (gestor da infraestrutura), Tenant Admin (gestor do RH da empresa) e Employee (colaborador).
2. **Módulo de Pesquisas (Surveys):** Permite a montagem de baterias de perguntas e distribuição estruturada aos funcionários. Cada pesquisa gera relatórios individuais de impacto.
3. **Módulo Analítico e de Diagnóstico (Analytics):** É o coração matemático do sistema. Ingressa milhares de respostas brutas em matrizes em memória e devolve relatórios executivos compilados em Markdown puro, destacando problemas e calculando a confiabilidade geral.
4. **Módulo de Planos de Ação (Action Plans):** Funciona como um painel Kanban ágil interno. Assim que os riscos são detectados no Analytics, o gestor pode levantar tarefas de mitigação, associar um prazo (deadline) e designar responsáveis, alterando os status (`OPEN` , `IN_PROGRESS` , `RESOLVED`).

8. Fórmulas de Cálculos e Referências Biográficas

Para sustentar o diagnóstico sem intervenção de inteligência artificial de terceiros, o *Statistical Engine* emprega os seguintes processos psicométricos e matemáticos, calcados na literatura científica:

Fórmula 1: Cálculo de Risco Individual e Severidade

Baseado nas matrizes de Avaliação de Risco Ocupacional, o sistema quantifica o impacto de um cenário.

- **Cálculo:** $Risco = Probabilidade (P) \times Impacto (I)$
- **Execução:** Ambas as variáveis são extraídas em pontuações numéricas das respostas. A multiplicação traduz o peso absoluto daquela vulnerabilidade na vida do colaborador. A média

deste escore define se o ambiente como um todo (ou o setor) está saudável (< 3), em atenção (3 a 6) ou em nível crítico (> 6).

Fórmula 2: Média, Variância e Desvio Padrão (Detecção de Polarização)

O cálculo da média aritmética tende a ocultar a desigualdade das percepções. Para contornar isso, o sistema avalia a polarização.

- **Variância (σ^2):** Calculada como a média dos quadrados das diferenças entre cada nota de risco individual e a média geral.
- **Desvio Padrão (σ):** Corresponde à raiz quadrada da Variância (`Math.sqrt(variance)`).
- **Regra de Negócio (Alerta de Polarização):** O sistema dispara a flag `isPolarized = true` caso o Desvio Padrão seja superior a 2.5 . Isto significa que no mesmo setor há funcionários reportando qualidade de vida altíssima e outros reportando burnout extremo.

Fórmula 3: Coeficiente Alfa de Cronbach (α)

É a principal métrica de confiabilidade estatística utilizada no sistema para medir a "consistência interna" do formulário. Evita que ações de RH sejam tomadas em cima de dados onde os usuários responderam aleatoriamente.

- **Cálculo:** $\alpha = (k / (k - 1)) * (1 - (\sum(\sigma^2_i) / \sigma^2_t))$
 - k = Número total de perguntas do Survey.
 - $\sum(\sigma^2_i)$ = A soma da variância das respostas para cada pergunta individual.
 - σ^2_t = A variância das pontuações totais computadas pelos respondentes.
- **Regra de Negócio:** Escores de $\alpha \geq 0.8$ indicam alta confiabilidade dos dados para embasar reestruturações corporativas, enquanto valores $\alpha < 0.6$ alertam que a amostra é inaceitável.

Referências Biográficas

As lógicas modeladas no código e os limiares de atenção (*thresholds*) utilizados no painel analítico possuem embasamento na literatura de gestão e psicologia:

- **Cronbach, L. J. (1951).** *Coefficient alpha and the internal structure of tests*. Psychometrika, 16(3), 297-334. (Fundamentação algorítmica para a consistência interna das pesquisas).
- **Nunnally, J. C., & Bernstein, I. H. (1994).** *Psychometric theory* (3rd ed.). McGraw-Hill. (Fornece as referências de corte para validação do Alfa de Cronbach, ex: $\alpha > 0.7$ denotando viabilidade).
- **ISO 31000:2018 - Risk management – Guidelines.** (Fundamentação estrutural para a métrica bivariável de Probabilidade x Impacto, empregada no sistema `type: PROBABILITY_IMPACT`).